TechZeen

AI-DRIVEN

CYBER SECURITY

YOUR RAG APPLICATION MIGHT GIVE ACCURATE ANSWERS TODAY, BUT ONE POISONED DOCUMENT OR A SINGLE ACCESS CONTROL MISTAKE COULD EXPOSE CONFIDENTIAL DATA TOMORROW.

TechZeen

WHAT IS RAG SECURITY?

- RAG COMBINES INFORMATION RETRIEVAL WITH AN LLM TO GENERATE CONTEXT-BASED ANSWERS.
- RAG SECURITY PROTECTS DOCUMENTS, VECTOR DATABASES, RETRIEVAL PROCESSES, AND GENERATED RESPONSES.
- GOAL: PREVENT DATA MANIPULATION, UNAUTHORIZED ACCESS, AND UNSAFE RETRIEVAL.

TechZeen

RAG DATA POISONING

- ATTACKERS INSERT MALICIOUS, MISLEADING, OR MANIPULATED CONTENT INTO A RAG KNOWLEDGE BASE.
- POISONED DOCUMENTS CAN INFLUENCE THE AI'S ANSWERS.
- EXAMPLE: A FAKE COMPANY POLICY TELLS THE CHATBOT TO PROVIDE AN ATTACKER'S EMAIL INSTEAD OF THE OFFICIAL SUPPORT ADDRESS.
- DEFENSE: VERIFY DOCUMENT SOURCES, CONTROL UPLOADS, AND MONITOR KNOWLEDGE-BASE CHANGES.

TechZeen

CROSS-TENANT DATA LEAKAGE

- A TENANT IS AN INDIVIDUAL CUSTOMER OR ORGANIZATION USING THE SAME APPLICATION.
- LEAKAGE OCCURS WHEN ONE TENANT RETRIEVES ANOTHER TENANT'S PRIVATE INFORMATION.
- EXAMPLE: COMPANY A'S CHATBOT RETURNS COMPANY B'S CONFIDENTIAL DOCUMENTS.
- DEFENSE: ENFORCE SERVER-SIDE AUTHORIZATION AND TENANT-LEVEL RETRIEVAL FILTERS.

TechZeen

RETRIEVAL ATTACKS

- ATTACKERS MANIPULATE QUERIES OR STORED CONTENT TO INFLUENCE WHICH DOCUMENTS THE RAG SYSTEM RETRIEVES.
- IRRELEVANT OR MALICIOUS DOCUMENTS MAY ENTER THE LLM'S CONTEXT.
- EXAMPLE: A CRAFTED QUERY RETRIEVES A MISLEADING SECURITY PROCEDURE INSTEAD OF THE APPROVED ONE.
- DEFENSE: VALIDATE QUERIES, RANK AND VERIFY RETRIEVED CONTENT, AND RESTRICT ACCESSIBLE DOCUMENTS.

TechZeen

VECTOR DATABASE SECURITY

- EMBEDDINGS REPRESENT THE MEANING OF TEXT AS NUMERICAL VECTORS.
- VECTOR DATABASES STORE AND RETRIEVE THESE REPRESENTATIONS AND THEIR ASSOCIATED DOCUMENTS.
- WEAK ACCESS CONTROLS OR METADATA FILTERS CAN EXPOSE UNAUTHORIZED INFORMATION.
- DEFENSE: ENFORCE AUTHENTICATION, AUTHORIZATION, TENANT ISOLATION, AND SECURE STORAGE.

TechZeen

SECURE RAG ARCHITECTURE

- VERIFY AND APPROVE DOCUMENTS BEFORE INGESTION.
- APPLY ACCESS CONTROLS BEFORE RETRIEVING DOCUMENTS.
- TREAT RETRIEVED CONTENT AS UNTRUSTED DATA.
- VALIDATE AI OUTPUTS AND PREVENT UNAUTHORIZED TOOL ACTIONS.
- LOG RETRIEVAL EVENTS AND REGULARLY TEST SECURITY CONTROLS.